

TechGlobal Security Governance Report

GRC102 Week 3 Practical Laboratory:

TechGlobal is a simulated technology company with approximately 2,500 employees in five offices. Its existing security decisions are concentrated with the IT Director, while business units operate inconsistently and the Board has limited visibility. This report proposes clear decision rights, cross-functional oversight and a path for material cyber risks to reach the Board.

Status of proposals: The committees, delegated authorities, meeting frequency, dates, examples and response targets below are recommendations for the simulation. They are not existing TechGlobal facts or statutory requirements. The Board and executive management would need to approve and adapt them before use.

Evidence Bundle 1: Governance architecture and stakeholder analysis

Governance gap assessment:

Current weakness	Business or risk consequence	Recommended action
IT Director is security owner, risk approver and operational decision-maker	One person can set, operate and approve controls without effective challenge.	Separate CISO governance, IT delivery and business risk acceptance.
No formal cross-functional committee	Important choices may be inconsistent, undocumented or delayed.	Create a monthly Security Governance Committee with a decision log.
Limited CEO and Board visibility	Material risk may not receive timely attention or funding.	Report risk trends and material issues through executives to the Board.
Business units decide locally	Offices may apply uneven controls and accept risks informally.	Use common policies and local owners who participate in central governance.
No reliable escalation path	Teams may keep significant issues at operational level.	Define operational, executive and material escalation criteria.
Risk acceptance authority is unclear	People may accept risk outside their authority.	Approve a delegated authority schedule tied to risk appetite.
Responsibilities and assurance are informal	Work can be missed; a team may verify its own controls.	Publish role profiles and RACI; independently verify significant closure.

Stakeholder map:

Stakeholder	Authority and interest	Information needed	Expected contribution
Board	Highest oversight; risk appetite and strategy	Material risks, trends, incidents, assurance	Approve appetite; challenge executives
CEO	Executive accountability; performance and acceptable risk	Risk posture, major decisions, investments	Sponsor model; resolve cross-functional issues

Stakeholder	Authority and interest	Information needed	Expected contribution
CISO	Security leadership; programme effectiveness	Control results, incidents, threats, exceptions	Set security requirements; advise and report
CRO or Risk	Enterprise risk methodology and aggregation	Risk register, treatment, acceptance	Challenge assessments; align with ERM
Legal and Compliance	Interpret legal, privacy and contract duties	Incident facts, obligations, contracts	Advise on obligations and notification
Finance	Budget and loss exposure	Costs, impacts, investment cases	Assess affordability and financial controls
HR	Workforce and conduct	Training, access changes, conduct issues	Own people processes and awareness
IT and Technology	Technical delivery and reliability	Requirements, findings, incidents	Implement and operate controls
Business unit leaders	Local business outcomes and risk	Unit exposure, standards, exceptions	Own local business risk and control adoption

Organization and communication paths:

The Board oversees risk appetite and receives material risk and assurance reports. The CEO sponsors the programme. A proposed CISO reports to the CEO outside the IT delivery chain and has direct access to the Board for material matters. The CRO also reports to executive management and independently challenges risk assessments. Legal, Finance, HR, IT and business units retain their normal management lines while serving on the committee.

Board | oversight and risk appetite

↓ material risk reports and executive accountability ↑

CEO | executive sponsor

↓ delegated decisions and resources ↑

Executive Security Council | strategic decisions

↓ direction and escalation ↑

Security Governance Committee | cross-functional decisions

↓ standards and actions ↑

Cloud Security Working Group and business unit representatives

↓ implementation and findings ↑

IT and operational teams

The councils and working group are decision forums, not a new line management hierarchy. Operational staff report through their managers; the CISO and CRO can also escalate directly through approved channels. This arrangement makes common rules practical across five offices while allowing local teams to carry out the work. A 2,500-person organisation needs delegation for routine decisions and executive review for significant ones.

Evidence Bundle 2: Responsibilities and decision authority

These eight profiles describe the proposed authority. Each KPI is a measure to define and monitor, not a claim that TechGlobal already meets a target. “Reports to” describes the proposed governance route, not every employment reporting line.

Role and purpose	Key responsibilities	Decision authority and reporting	Two example indicators
Board: oversight	Set appetite, review material risk, challenge management and assurance.	Approves risk appetite and strategy within corporate governance; receives CEO and CISO reports.	Material risks reviewed, reporting cadence met.
CEO: executive accountability	Sponsor programme; allocate resources; resolve cross-functional disputes.	Approves policy and investment within delegation; reports material matters to Board.	Overdue significant actions; executive decisions recorded.
CISO: security leadership	Draft strategy and policy; set standards; assess security; oversee incidents and control performance.	Approves standards and designs within delegation; reports to CEO and committee and accesses Board when material.	Policy exceptions overdue; significant findings verified closed.
CRO or Risk: enterprise risk integration	Set risk method; challenge assessment; maintain enterprise view.	Owns risk method, not unilateral business risk acceptance; reports aggregate exposure to executives and Board.	Risk reviews on schedule; overdue treatments.
Legal and Compliance: legal advice	Identify applicable duties; review contracts, privacy and notification.	Determines legal interpretation and coordinates notification decisions; escalates to CEO where required.	Obligations assessed on time; notification decisions documented.
Finance: financial governance	Assess business cases, budgets and financial exposure.	Applies financial controls and delegated approval; reports via CFO and council.	Budget variance; investment reviews completed.
HR: workforce governance	Manage joiner, mover and leaver controls, awareness and conduct.	Approves HR processes; reports people-related control results to committee.	Training completion; timely leaver access removal.
IT: technology delivery	Implement controls, patch, log, back up and recover services.	Makes operational choices within approved standards; reports status to management and committee.	Patch compliance; recovery exercise results.

Overlapping authority and resolution:

1. CISO and IT: The CISO sets security outcomes and assesses exceptions, IT designs and operates the solution. A design dispute goes to the Security Governance Committee and then the Executive Security Council verifies if it exceeds delegated authority.
2. CISO and CRO: The CISO assesses cyber exposure and provides cybersecurity expertise, while the CRO provides the enterprise risk framework and independent challenge. Risk acceptance remains with an authorized business owner acting within their delegated authority; neither the CISO nor the CRO unilaterally accepts enterprise business risk.

3. CISO and Legal: The CISO establishes technical facts and severity. Legal interprets applicable notification duties. The authorised executive approves the corporate response on both inputs, with any mandatory legal deadline followed.
4. Business unit and Security: The business owner assesses the operational impact; the CISO evaluates the cybersecurity exposure, and the CRO provides independent challenge to the risk rating. Any exceptions require documented, time-limited approval at the appropriate risk-authority level.

Evidence Bundle 3: Committee ecosystem and governance records

Forums and information flow:

Forum	Members and frequency	Authority and output
Executive Security Council	CEO chairs; CISO, CRO, Legal, Finance, Technology; quarterly and urgently when needed.	Reviews strategic risks, investment and unresolved exceptions; sends material matters to Board.
Security Governance Committee	CISO chairs; Risk, Legal, Finance, HR, IT and business unit representatives; monthly.	Reviews risk, controls, policy and exceptions within delegation; records decisions and escalations.
Cloud Security Working Group	Security, cloud IT and affected business owners; monthly or for urgent changes.	Analyses designs, identity, configuration, logging and findings; recommends action to committee.

Each business unit appoints a designated representative who reports local risks and implementation evidence to the central committee and communicates approved actions back to their teams. Significant operational findings are escalated from the working group or business unit to the central committee, then to the Executive Security Council and, where the defined threshold is met, to the Board. Risk information flows upward, while approved policies, decisions, and actions flow downward.

Terms of reference for the Security Governance Committee:

Item	Proposed rule
Purpose	Make cross-functional decisions on cyber risk, policy, compliance, investment and control performance.
Chair and membership	CISO chairs; Risk, Legal, Finance, HR, IT and each business unit participate. A secretary maintains records.
Authority	Decide within written executive delegation. Refer out-of-tolerance risk, disputed decisions and strategic funding to the Executive Security Council.
Meetings and quorum	Monthly; extraordinary meeting for urgent matters. Chair or delegate, Risk and at least half of voting functions present.
Decision process	Seek consensus. Record dissent and escalate unresolved issues; do not treat silence as approval.
Records and review	Keep minutes, decisions, risk and action registers with owners and deadlines. Review the terms annually or after major change.

Sample monthly agenda:

- 1. Confirm minutes and action status.
- 2. Review risk register, new risks and overdue treatments.
- 3. Review incidents and lessons.
- 4. Review vulnerabilities, access, suppliers and business unit reports.
- 5. Review policy exceptions and legal or compliance matters.
- 6. Decide proposals within delegation.
- 7. Assign owners and deadlines.
- 8. Escalate matters beyond authority.

Illustrative decision log:

Date	Issue and decision	Authority and reason	Action owner and review
01 Oct 2026	Require MFA for privileged accounts.	Committee within proposed standards authority; unauthorised access exposure.	IT implements, CISO verifies; 31 Oct 2026.
05 Nov 2026	Remediate critical cloud configuration findings and review similar systems.	Committee directs remediation; possible repeated weakness.	Cloud team implements, CISO checks; 30 Nov 2026.
03 Dec 2026	Hold expanded supplier access until security weakness is treated.	Business owner and committee within delegation; supplier exposure.	Supplier owner, Legal and CISO; 15 Jan 2027.

These dates and events are invented examples for the decision-log template, not actual incidents at TechGlobal.

Twelve month governance calendar:

Month	Main activity	Month	Main activity
January	Strategy and enterprise risk review	July	Midyear budget and programme review
February	Policy and standards review	August	Access and privileged access review
March	Q1 Council and Board risk report	September	Q3 Council and risk reassessment
April	Supplier risk review	October	Incident response exercise and lessons
May	Awareness and workforce risk	November	Architecture and technology risk review
June	Q2 Council and recovery review	December	Q4 Council, performance and next-year plan

Every month: Security Governance Committee and risk/action review. Cloud Security Working Group meets monthly or as needed. Material issues are escalated as soon as identified, without waiting for the next scheduled meeting.

Evidence Bundle 4: RACI matrix and implementation guide

R = performs the work; A = owns the outcome or final internal decision; C = consulted before the decision; I = informed. Blank means no standing role. Each activity below has one A. CEO authority is subject to Board-approved delegation, and legal notification duties depend on the applicable jurisdiction.

Activity	Board	CEO	CISO	Risk	Legal	Fin.	HR	IT	BU
Cybersecurity strategy approval	A	C	R	C	C	C	I	C	C
Security policy approval	I	A	R	C	C	I	C	C	C
Enterprise cyber-risk assessment	I	C	R	A	C	C	C	C	C
Risk acceptance of significant enterprise risk	I	A	C	R	C	C		C	R
Security budget approval	I	A	R	C		R		C	
Security architecture approval		I	A	C	C			R	C
Third-party security review			A	C	C			R	R
Access governance			A	C	C		R	R	C
Incident response governance	I	C	A	C	C		C	R	C
Material incident escalation	I	A	R	C	C			R	C
Regulatory notification decision	I	C	R	C	A			C	
Security awareness programme			R	C	C		A	I	C
Vulnerability remediation oversight			A	C				R	C
Business continuity and recovery governance	I	C	C	A	C	C	C	R	R
Board cyber-risk reporting	I	A	R	R	C				

Risk acceptance row covers significant enterprise risk only. TechGlobal should delegate lower risks to an authorised business owner and escalate risks outside appetite to the Executive Security Council and Board for oversight. Board approval may also be required for a budget beyond management delegation. Legal owns the internal notification decision with the accountable executive consulted, the actual legal duty and deadline must be checked for the affected jurisdiction.

Assignments that require care:

1. IT Independence and Control Assurance:

IT must not implement a control, approve its own exception, and independently certify that the control is effective.

IT is responsible for implementation and remediation; the **CISO verifies significant control closure, while Risk retains the ability to independently challenge the assessment.

2. Security Risk Acceptance: The CISO provides advice on security exposure and associated risks but should not accept business risks on behalf of the organization. The business owner, together with the appropriately authorized executive, is responsible for accepting risk within the applicable delegated authority limits.

3. Clear Accountability:

Assigning the CEO, CISO, and CRO as equally accountable for a single decision can obscure who holds final authority.

One individual should remain accountable for the defined activity, with the CEO, CISO, CRO, and other relevant stakeholders consulted when appropriate.

4. Board and Executive Responsibilities:

The Board should provide oversight, receive reporting, and challenge management rather than direct operational incident response. The CEO remains accountable for material escalation, executive decision-making, and ensuring appropriate management action is taken.

Evidence Bundle 5: Cyber risk escalation

Major cyber risk workflow:

- 1.** An operational team identifies an incident, weakness or exception and creates a unique record. For an active incident, it also starts the incident response plan immediately.
- 2.** IT or the business owner assesses affected systems, likely impact, likelihood, existing controls and uncertainty with CISO input. Legal is consulted if contractual, privacy or regulatory duties might arise.
- 3.** The owner compares the exposure with approved risk appetite and delegation. Level 1 matters receive local treatment and tracked review.
- 4.** A significant issue, multi-unit impact or risk above local authority goes to Level 2: CISO and CRO brief the CEO or Executive Security Council. The authorised owner decides treatment and resources.
- 5.** A material issue or risk outside enterprise appetite goes to Level 3: CEO informs Board leadership promptly. The Board provides oversight or approval within its reserved powers; executives implement the response.
- 6.** The secretary or risk function logs the decision, rationale, approver, consulted roles, actions, dates and supporting evidence. The CISO verifies significant technical closure, Risk reviews residual exposure, and the owner authorises closure.

Escalation thresholds

Level	Illustrative trigger	Decision authority and notice	Proposed internal target
1. Operational	Local issue with limited impact, within approved tolerance and delegated authority.	IT or authorised business owner decides; notify CISO when relevant.	Initial triage within one business day.
2. Executive	High exposure; multiple units; major outage; sensitive data concern; or beyond operational authority.	CEO or Council under written delegation; notify CISO, CRO, Legal and affected owner.	Escalate significant issues on the same day; escalate active incidents immediately.
3. Material and Board	Potential material effect on strategy, finances, legal duties, reputation or continued service; or outside enterprise appetite.	CEO alerts Board leadership; Board oversight or reserved approval; CISO, CRO and Legal advice.	Escalate immediately after materiality is recognised.

These are internal example targets, not legal notification deadlines. TechGlobal must define measurable financial, operational and data-impact thresholds after its risk appetite is approved. “Immediately” means use the incident escalation channel as soon as materiality is identified, not wait for the next committee meeting.

Evidence Bundle 6: Segregation of duties and assurance

Accountability weakness register:

ID and weakness	Risk created	Practical control	Residual review
1. IT Director owns security, accepts risk and runs IT	No independent challenge or separation of approval and delivery.	CISO sets requirements; IT delivers; business owner accepts within delegation; CRO challenges.	Quarterly review of delegation and exceptions.
2. Administrator requests and approves own privileged access	Excess access or abuse can go undetected.	Separate manager approval and periodic privileged-access review.	Review exceptions monthly or by risk.
3. IT marks its own significant findings closed	Incomplete repairs can appear resolved.	CISO verifies closure evidence for significant findings.	Track reopenings and overdue items.
4. Architect designs and approves own security exception	Conflict can bias the exception decision.	Time-limited approval by authorised risk owner after CISO and CRO advice.	Reassess before expiry.

ID and weakness	Risk created	Practical control	Residual review
5. Technical responders decide legal notification alone	Legal duty may be missed or misread.	Legal evaluates duties against verified facts; executive approves response.	Reassess if incident facts change.
6. Supplier owner selects vendor and accepts its security risk	Commercial pressure can override security assessment.	Independent security review; Legal and Risk join higher-risk approvals.	Recheck at renewal or major change.

Decision recording and assurance

Use one central decision register linked to the risk and action registers. Each significant entry should state a unique ID, date, issue, affected assets or business process, level, assessment and uncertainty, options, final decision, rationale, authorised approver, participants, treatment owner, due date, review date, evidence and status. Record any dissent and the reason for escalation. Preserve earlier entries when a risk rating or decision changes.

At review, the action owner supplies evidence; the CISO verifies significant security fixes; CRO or Risk checks remaining exposure; the authorised owner signs off closure or records further treatment. The committee samples overdue and recently closed entries, and the Executive Security Council receives trends and unresolved high exposure. This leaves an auditable chain from detection through approval, action and closure.

References and submission note

NIST, The NIST Cybersecurity Framework 2.0, 2024, Govern function, especially Roles Responsibilities and Authorities (GV.RR) and Oversight (GV.OV): <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf>

NIST, IR 8286 Rev. 1, Integrating Cybersecurity and Enterprise Risk Management, 2025: <https://csrc.nist.gov/pubs/ir/8286/r1/final>

These sources support the general approach to roles, oversight and enterprise risk integration. TechGlobal committees, RACI assignments and thresholds are recommendations for this fictional case, not requirements stated by NIST.